LABORATUVAR 5 · SCHNITZER 2×2 · CNC Ahşap Torna

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	30.10.2026

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: **bileşen var, sürüm etkileniyor, açık ulaşılabilir.**
Schnitzer bağlamı: Föydeki hayali "Component X" yerine makinemizin gerçek kontrol ünitesi için yayımlanmış **gerçek bir Siemens güvenlik bültenini** kullandık. Bileşen listesi Lab 2 envanterinden (Y-1 … Y-6) geliyor.

SBOM taslağı — makinedeki yazılımlar

EK SORU

SBOM olmadan bir CVE'nin bizi etkileyip etkilemediğini bilemeyiz. Bu yüzden önce makinenin yazılım listesini çıkardık. Sürümler üretici sayfasında yok, sahada kontrol ekranından okunacak (VS-7).

ID	Bileşen	Sağlayıcı	Sürüm	Nereden ulaşılır
Y-1	SINUMERIK 808D sistem yazılımı (CNC firmware + entegre yazılım güvenlik duvarı)	Siemens	Sahada okunacak (VS-7)	X130 Ethernet portu · USB
Y-2	808D PLC kullanıcı programı (kapak, pnömatik mantığı)	Schnitzer	Üreticiden istenecek	Ethernet · USB · servis
Y-3	Makine parametreleri (hız sınırları)	Schnitzer	Arşiv tarihi ile	Ethernet · USB · panel
Y-4	Servo ve iş mili sürücü firmware'i	Siemens	Sahada okunacak	Sürücü üzerinden, CNC aracılığıyla
Y-5	Schnitzer CAM yazılımı (2D → G-kodu)	Schnitzer	Üreticiden istenecek	CAM PC
Y-6	CAM PC işletim sistemi + uzak masaüstü yazılımı	Üçüncü taraf	Sahada okunacak	İnternet · fabrika ağı

Not: Y-5 için CRA kapsamında üreticiden **SBOM ve destek süresi** istenir. Bugün bu bilgi yok, bu da bir bulgu.

Verilen zafiyet kaydı

UYARLANDI

Alan	Değer
Bileşen	SINUMERIK 808D sistem yazılımı (Y-1), entegre yazılım güvenlik duvarı
Sürüm	V4.7 ve V4.8, yani **V4.91'den eski tüm sürümler**
CVE	**CVE-2018-11466** · Siemens SSA-170881 · CISA ICSA-18-345-02
Önem	**Critical (CVSS 10.0)**: ağdan, kimlik doğrulamasız, 102/tcp (ISO-TSAP) portuna özel paketle güvenlik duvarını çökertme veya kod yürütme
Yama	**Mevcut:** V4.91'e güncelleme (Siemens satış temsilcisinden temin edilir) + üreticinin önerdiği önlemler

Görev — karar akışı

1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Şart	Bu makinede	Sonuç
Bileşen var mı?	Makinede SINUMERIK 808D kontrol ünitesi var	✅ Var
Sürüm etkileniyor mu?	Sürüm bilinmiyor. Kontrol ekranından okunacak, V4.91'den eskiyse etkilenir	⚠️ Doğrulanacak (VS-7)
Açık ulaşılabilir mi?	102/tcp, 808D'nin X130 Ethernet portundan erişilir. Bugünkü durumda CAM PC aynı ağda ve internete açık (VS-4), yani saldırgan iki adımda ulaşır	✅ Ulaşılabilir

Karar: Sürüm doğrulanana kadar makine **etkileniyor kabul edilir.** Sürüm V4.91 veya üstü çıkarsa kayıt "etkilenmiyor" olarak kapatılır, ama kanıtı (sürüm ekranının fotoğrafı) EP 10'a eklenir.

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Hayır, otomatik olarak değil. CVSS açığın ciddiyetini ölçer, makinenin emniyetini değil. Önce **saldırı yolunu hemen kapatırız:** 808D'nin Ethernet bağlantısını CAM PC dışındaki her şeyden ayırır, uzak erişimi kapatırız. Yol kapandığında üretim devam edebilir. **Durdururuz ancak** istismar belirtisi varsa: beklenmeyen parametre değişikliği, CNC'nin kendiliğinden yeniden başlaması, açıklanamayan hız değişimi. O durumda makine güvenli duruma alınır, kayıtlar silinmeden korunur (Lab 6).

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. CNC firmware'i değişince makine üreticisinin PLC programı ve parametreleri yeni sürümle uyumsuz kalabilir. Sıra:

- **Yedek:** güncellemeden önce tam CNC arşivi alınır (PLC programı, makine parametreleri, programlar)
- **Uyumluluk onayı:** Schnitzer, PLC programının V4.91 ile çalıştığını yazılı onaylar
- **Test yeri:** üreticinin aynı kontrol ünitesine sahip test tezgâhı. Yoksa makinenin kendisi, **üretim dışı bir bakım penceresinde** ve geri dönüş planıyla
- **Geri dönüş:** sorun çıkarsa eski arşiv geri yüklenir
- **Kayıt:** kim, ne zaman, hangi sürümden hangisine (EP 11)

4 Bu yama bir safety validation'ı etkiliyor mu? Nasıl anlarsınız?

Evet, etkiliyor kabul ediyoruz. Lab 1'deki varsayıma göre (VS-3) kapak açma izni ve iş mili hız sınırı CNC'nin PLC'sinde ve parametrelerinde. CNC firmware'ini değiştirmek bu fonksiyonların çalıştığı ortamı değiştirir. Nasıl anlarız:

- **Etki analizi:** yama hangi emniyet fonksiyonuna dokunuyor? Lab 1'deki SF listesi üzerinden tek tek bakılır
- **Fark kontrolü:** güncelleme öncesi ve sonrası PLC programı ile parametre arşivi karşılaştırılır. Hız sınırı değerleri aynı kalmalı
- **Fonksiyon testleri:** SF-1 E-stop durdurur · SF-2 kapak açıkken iş mili dönmez ve iş mili durmadan kapak açılmaz · SF-3 punta basıncı düşükken iş mili başlamaz · SF-4 azami hız aşılamaz
- **Kayıt:** test sonuçları imzalı olarak EP 15'e (Verification/Test) eklenir

Kablolu güvenlik rölesi zinciri (VS-2) firmware'den etkilenmez, ama yine de test edilir: "etkilenmez" bir beyandır, test ise kayıttır.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

- **Ağ izolasyonu:** 102/tcp'ye yalnızca CAM PC ulaşır, başka hiçbir yerden ulaşılamaz (Lab 2, C3). Gerekirse Ethernet tamamen kapatılır, program aktarımı kontrollü USB ile yapılır (C4)
- **Güvenlik duvarı varsayılanları:** X130 portunda 4842/tcp ve 5900/tcp kapalı mı kontrol edilir (Siemens önerisi)
- **Uzak erişim:** varsayılan kapalı, jump server + VPN + MFA (Lab 4)
- **En az yetki:** kişisel hesaplar, değiştirilmiş varsayılan parolalar (aynı bültendeki yerel yetki yükseltme açıklarına karşı da)
- **İzleme:** CNC'nin beklenmedik yeniden başlamaları kaydedilir, parametre arşivi haftalık karşılaştırılır
- **Emniyet bağımsızlığı (en güçlü önlem):** GR-1 ... GR-4. CNC ele geçse bile kapak kilidi ve hız sınırı insanı korur
- **Kayıt:** EP 10'a "yama ertelendi" kararı, telafi önlemleri ve yeniden değerlendirme tarihi yazılır

Ek sorularımız

6 Aynı bültendeki CVE-2018-11457 (CVSS 9.8, web sunucusu 4842/tcp) bizi etkiler mi? EK SORU

Hayır. Siemens bülteninde 808D bu CVE için listelenmiyor, açık 828D ve 840D sl modellerini etkiliyor. Bileşen şartı sağlanmadığı için puanı ne kadar yüksek olursa olsun bizim için geçerli değil. Bazı ikincil veritabanları bunu farklı gösterebiliyor, bu yüzden karar her zaman **üreticinin kendi bültenine** göre verilir. Ders: yüksek CVSS gördüğünde panik yapma, önce üç şartı kontrol et.

7 CVE-2018-11465 (CVSS 7.8, yerel) ile CVE-2018-11466 (CVSS 10.0, ağ) arasında hangisi önce? EK SORU

CVE-2018-11466. Ağdan ve kimlik doğrulaması olmadan istismar edilir. CVE-2018-11465 ise makineye yerel erişim ve kullanıcı yetkisi gerektirir, yani yalnızca makine başından (Lab 3'teki E=1). İkisi de aynı güncellemeyle (V4.91) kapanır, ama yama gelene kadar telafi önlemlerinde öncelik ağ izolasyonundadır.

8 Bu CVE Risk Register'ı nasıl değiştirir? EK SORU

Lab 3'teki kural: yeni bir açık çıktığında L puanı değişir. Bu CVE için yeni bir satır açtık:

R-05: Fırsatçı dış → CAM PC (B-1) → fabrika ağı → 808D 102/tcp (CVE-2018-11466) → CNC'de kod yürütme → hız sınırı / kapak mantığı değişir (SF-4, SF-2) → fırlayan parça veya dolanma, ağır yaralanma.

Durum	L · S · E	Skor
Bugün (yamasız, CAM PC aynı ağda)	3 · 3 · 2	**18 · Kritik**
Ağ izolasyonu (102/tcp yalnız CAM PC'den, uzak erişim kapalı)	3 · 3 · 1	**9 · Yüksek**
Yama V4.91 + izolasyon	1 · 3 · 1	**3 · Düşük ⚑ S3**
+ Emniyet bağımsızlığı	1 · 1 · 1	**1 · Düşük**

L=3 çünkü kimlik doğrulama gerekmiyor ve açık kamuya duyurulmuş. E=2 çünkü CNC doğrudan internette değil, fabrika ağından ulaşılıyor. Yama L'yi, izolasyon E'yi düşürür. S'yi yine yalnızca emniyet tasarımı düşürür.

Vulnerability Decision (föyün çıktısı)

Alan	Karar
Kayıt	V-01 · CVE-2018-11466 · SINUMERIK 808D < V4.91
Etkileniyor mu?	Sürüm doğrulanana kadar **evet** (VS-7)
Hemen	Ağ izolasyonu + uzak erişim kapalı (bugün)
Karar	**Yamala:** V4.91, üretici onayı + test + safety validation sonrası

Alan	Karar
Sahip (RACI)	A: Yönetim · R: OT + Servis (Schnitzer) · C: Safety
Hedef tarih	30 gün (Kritik bant)
Yama olmazsa	Telafi önlemleri (soru 5) + 90 günde yeniden değerlendirme

Varsayımlar

Yeni varsayım VS-7: CNC sistem yazılımının sürümü bilinmiyor. Kötü durum olarak V4.91'den eski kabul edildi. VS-2, VS-3 ve VS-4 de bu föyde kullanıldı (bkz. Makine Profili).

Kaynaklar

- Siemens SSA-170881 — SINUMERIK güvenlik bülteni
- CISA ICSA-18-345-02 özeti
- CVE-2018-11465 kaydı

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 SBOM · EP 10 Vulnerability Records · EP 11 Patch/Update Records** başlığına oturur. Durum: **Taslak**.